

CSP: Failure to Define Directive with No Fallback

Assessment Identifier: **WS-DYN-00** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 5.4	CWE: CWE-693
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 15	Confidence: High
Target / Component: Web Application Header (CSP Directives)	Affected URL: https://www.worldmonitor.app/embed?zoom	Parameter: Content-Security-Policy

1. Description

The Content Security Policy (CSP) fails to define one of the directives that does not fall back to default-src. Certain CSP directives—specifically frame-ancestors, form-action, base-uri, and sandbox—do not inherit values from the generic default-src directive. Omitting them from the CSP definition allows the browser to default to permitting any origin/behavior for that feature, potentially leaving the application vulnerable to Clickjacking or UI redressing attacks.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/embed?zoom.
2. Inspect the Content-Security-Policy header in the HTTP response body.
3. Observe that specific non-fallback directives (such as frame-ancestors) are either missing, empty, or incorrectly defined.

3. Controlled Proof of Concept

```

HTTP
Content-Security-Policy: default-src 'self'; connect-src 'self' https: wss: blob: data:; img-src 'self' data
: blob: https:; style-src 'self' 'unsafe-inline'; script-src 'self'; worker-src 'self' blob:; font-src 'self
' data: https:; media-src 'self' data: blob: https:; frame-src 'none'; frame-ancestors ''; base-uri 'self'; o
bject-src 'none'; form-action 'none'

Verification Bash:
curl -I -s "https://www.worldmonitor.app/embed?zoom" | grep -i "content-security-policy"
  
```

4. Business & Security Impact

Directives like frame-ancestors govern which external sites can embed the application within an <iframe>, <frame>, <embed>, or <applet>. If frame-ancestors is omitted or malformed, attacker-controlled malicious websites can frame this application page and execute Clickjacking attacks, tricking authenticated users into making unintended UI actions.

5. Remediation Recommendations

Primary Fix: Ensure all non-fallback CSP directives (frame-ancestors, form-action, base-uri) are explicitly and validly defined in the policy.

1. Ensure all non-fallback CSP directives (frame-ancestors, form-action, base-uri) are explicitly and validly defined in the policy.
2. To prevent the site from being framed by external sites (mitigating Clickjacking), set frame-ancestors to 'none' or 'self':
Content-Security-Policy: ... frame-ancestors 'none';

3. Regularly audit CSP deployments using automated policy evaluators.

6. Evidence & Validation

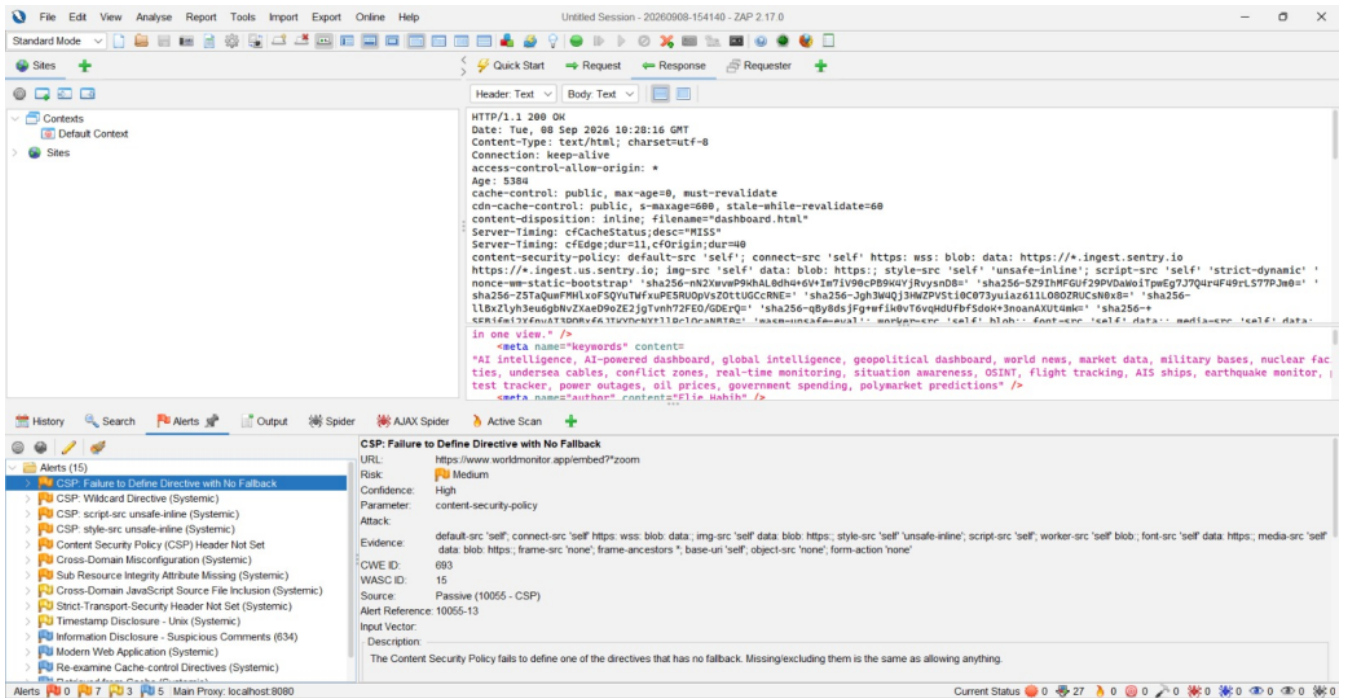


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #0 (0/poc-1.png)

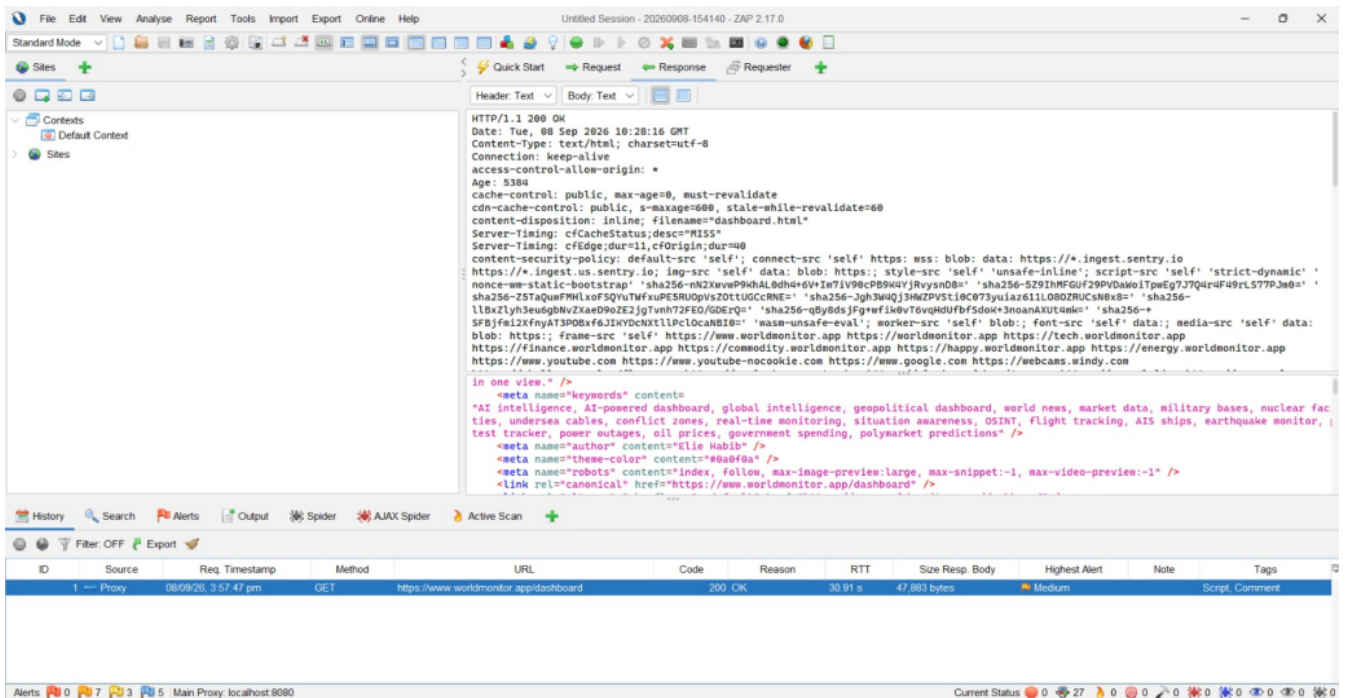


Figure 2: Matched Proof-of-Concept Screenshot for Vulnerability #0 (0/poc-2.png)

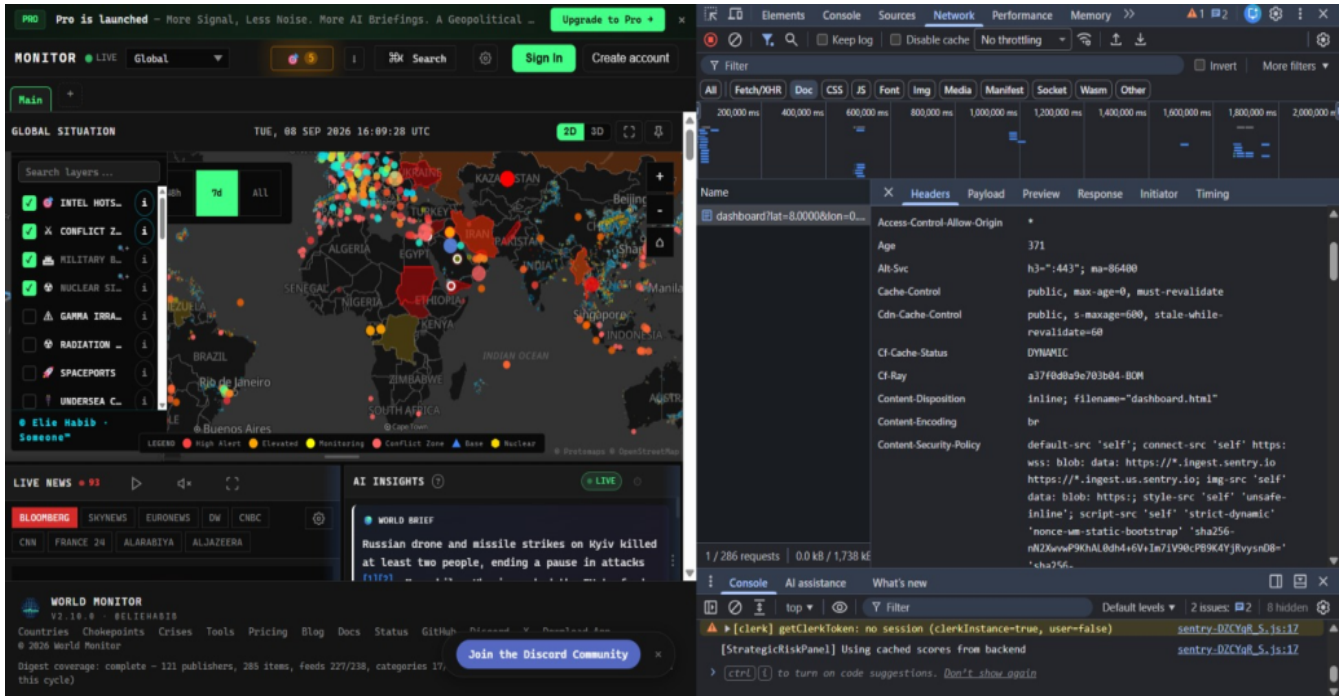


Figure 3: Matched Proof-of-Concept Screenshot for Vulnerability #0 (0/poc-3.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.